

MITRE ATT&CK

Software Research Report

S0010 - S0020 | 11 Software Entries

Course Assignment - Threat Intelligence & Malware Analysis

Generated: May 14, 2026

TABLE OF CONTENTS

#	Software ID	Name	Type
1	S0010	Lurid	Malware
2	S0011	China Chopper	Malware / Webshell
3	S0012	PoisonIvy	Malware / RAT
4	S0013	PlugX	Malware / RAT
5	S0014	Regin	Malware / Advanced Persistent Backdoor
6	S0015	Ixeshe	Malware / RAT
7	S0016	Wing	Malware / Downloader
8	S0017	BISCUIT	Malware / Backdoor
9	S0018	Sykipot	Malware / RAT / Backdoor
10	S0019	Reaver	Malware / Backdoor
11	S0020	China Chopper	Malware / RAT

S0010

Lurid

Malware

01 DESCRIPTION & OVERVIEW

Lurid (also known as the 'LURID Downloader') is a remote access Trojan (RAT) and downloader malware family active since at least 2006. It is characterized by its modular architecture, enabling operators to download and execute additional payloads on compromised hosts. Lurid was prominently used in large-scale cyber-espionage campaigns targeting diplomatic missions, government ministries, space-related agencies, and research institutions across Russia, the CIS region, and beyond.

Threat Actor Association

PittyTiger (G0011); also attributed to Chinese-nexus APT operators in multiple independent campaigns.

Supported Platforms

Windows

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1059.003	Command and Scripting Interpreter: Windows Command Shell
T1071.001	Application Layer Protocol: Web Protocols (HTTP C2)
T1105	Ingress Tool Transfer
T1082	System Information Discovery
T1016	System Network Configuration Discovery
T1057	Process Discovery
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys
T1041	Exfiltration Over C2 Channel
T1027	Obfuscated Files or Information
T1140	Deobfuscate/Decode Files or Information

03 OPERATIONAL DETAILS

Execution Method

Lurid is typically delivered via spear-phishing emails with malicious attachments (PDF or Office exploits). Upon opening, a dropper installs the RAT. It can also be fetched as a second-stage payload from a C2 server after an initial lightweight downloader establishes a foothold.

Persistence Techniques

Achieves persistence by writing registry Run keys (HKCU\Software\Microsoft\Windows\CurrentVersion\Run) or by placing a startup entry to ensure execution on every logon.

Privilege Escalation

Lurid primarily operates under the user context of the initial infection. It relies on social engineering to obtain initial admin-level access rather than exploiting local privilege escalation vulnerabilities directly.

Defense Evasion

Uses obfuscated configuration blocks and encrypted communications. Files may be disguised with benign-looking names. Some variants use DLL side-loading to execute within the context of a legitimate process.

Credential Access

Does not natively implement credential harvesting; however, operators commonly deploy secondary tools (e.g., password dumpers) via the Lurid downloader functionality.

Discovery Techniques

Collects system information including OS version, computer name, running processes, and network configuration to profile victims for further targeting.

Lateral Movement

Lateral movement is achieved through secondary payloads downloaded via C2. Does not include a built-in lateral movement module.

Command & Control (C2)

Uses HTTP-based C2 communication. Beacons to hardcoded or generated C2 domains/IPs. Commands and data are exchanged over plain HTTP or simple encoded HTTP POST requests. Some campaigns leveraged dynamic DNS domains.

Exfiltration

Data (screenshots, files, keylog output) is exfiltrated over the established C2 HTTP channel, typically encoded or compressed before transmission.

Impact Analysis

Lurid enabled large-scale espionage operations against 1,465+ unique victims in 61 countries. Key impact includes theft of sensitive diplomatic and government documents, persistent access for prolonged intelligence gathering, and compromise of space-agency and research systems.

04 INDICATORS OF COMPROMISE (IOCs)

- C2 Domains: Various dynamic DNS (e.g., *.3322.org, *.8866.org) – campaign-specific
- Registry: HKCU\Software\Microsoft\Windows\CurrentVersion\Run – 'lurid' or random name
- File Artifacts: Dropped DLLs with random or system-mimicking names in %TEMP% or %APPDATA%
- Network: Beaconsing HTTP GET/POST to C2 at regular intervals
- Hashes: Multiple MD5s documented in Trend Micro's 2011 Lurid report

05 DETECTION & MITIGATION

Monitor registry Run key modifications. Inspect outbound HTTP traffic for beaconing patterns. Deploy endpoint detection rules for suspicious DLL loading in system directories. Use threat intelligence feeds for known Lurid C2 domains/IPs. Network-level blocking of dynamic DNS providers abused by the campaign.

06 REFERENCES & SOURCES

- [1] Villeneuve, N., Sancho, D. (2011). The 'LURID' Downloader. Trend Micro.
- [2] Villeneuve, N., Homan, J. (2014, July 31). Spy of the Tiger. FireEye.
- [3] MITRE ATT&CK;: <https://attack.mitre.org/software/S0010/>

S0011

China Chopper

Malware / Webshell

01 DESCRIPTION & OVERVIEW

China Chopper is a small, lightweight web shell (the client binary is only ~4KB) that provides adversaries with remote access to web servers. First observed around 2012, it has been widely adopted by Chinese-nexus APT groups as well as criminal actors globally. China Chopper consists of two components: a tiny server-side script (ASP, ASPX, PHP, JSP, CFM) injected into a compromised web server, and a Windows-based client used to interact with the implant.

Threat Actor Association

APT10 (G0045), APT19 (G0073), APT41 (G0096), Leviathan (G0065), Threat Group-3390 (G0027), menuPass (G0045), and multiple other Chinese-nexus groups.

Supported Platforms

Windows, Linux (server-side script on any web server platform)

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1505.003	Server Software Component: Web Shell
T1059.003	Command and Scripting Interpreter: Windows Command Shell
T1059.004	Command and Scripting Interpreter: Unix Shell
T1083	File and Directory Discovery
T1105	Ingress Tool Transfer
T1041	Exfiltration Over C2 Channel
T1070.004	Indicator Removal: File Deletion
T1027	Obfuscated Files or Information
T1078	Valid Accounts
T1190	Exploit Public-Facing Application

03 OPERATIONAL DETAILS

Execution Method

Deployed by uploading a malicious web shell script to a publicly accessible web server, typically by exploiting a vulnerability (e.g., SQL injection, file upload flaw, CVE in web application). The server-side code is minimal (e.g., one-liner PHP eval() or ASP execute()). The attacker then connects via the China Chopper client to issue commands.

Persistence Techniques

Persistence is inherent in the web shell file residing on the web server. As long as the web server runs and the shell file exists, access is maintained. No additional registry or startup modifications are needed.

Privilege Escalation

Operates under the web server process privilege (often IUSR, www-data, or SYSTEM). Operators may use the shell to deploy privilege escalation exploits to gain SYSTEM/root.

Defense Evasion

The server-side component is a tiny, obfuscated one-liner script that blends into web application files. Traffic uses standard HTTP/HTTPS, making it difficult to distinguish from legitimate web traffic. Operators may use file timestomping to alter shell metadata.

Credential Access

Via the command shell, attackers can dump credentials using Mimikatz, access SAM hive, or harvest credentials from web application configuration files.

Discovery Techniques

Full file system browsing, directory listing, and process enumeration via the web shell client GUI. Also enables network reconnaissance from the server.

Lateral Movement

Attackers use China Chopper as a pivot point to deploy additional tools (RATs, tunnels) for lateral movement into the internal network.

Command & Control (C2)

HTTP or HTTPS-based C2 with the client tool connecting directly to the web shell URL. Commands are encoded (often Base64 or custom encoding) and sent in HTTP POST bodies. Uses the web server's existing port (80/443), evading firewall rules.

Exfiltration

Files are downloaded directly via the web shell interface over HTTP/HTTPS. Bulk data can be compressed and staged before exfiltration.

Impact Analysis

Provides persistent, stealthy access to compromised web servers. Enables data theft, further network compromise, and destructive operations. Widely used in espionage campaigns targeting healthcare, defense, finance, and government sectors globally.

04 INDICATORS OF COMPROMISE (IOCs)

- Server-side: `eval(Request.Item[...])` in ASPX; in PHP
- File: Presence of tiny (<5KB) `.asp/.aspx/.php` scripts with eval-based execution
- Network: HTTP POST to `.asp/.aspx/.php` files with Base64-encoded body
- Client: `chopper.exe` (MD5: various); connects to shell via HTTP POST
- UA String: May use custom or spoofed User-Agent headers

05 DETECTION & MITIGATION

Implement web application firewalls (WAF) with rules for eval-based web shells. Monitor web server logs for POST requests to static or unexpected files. Use file integrity monitoring (FIM) on web root directories. Scan for known one-liner web shell signatures with tools like NeoPI or webshell-detector. Alert on abnormal process spawning from web server processes (e.g., `w3wp.exe` spawning `cmd.exe`).

06 REFERENCES & SOURCES

- [1] FireEye. (2013). Trojan.APT.9002 / China Chopper. FireEye Blog.
- [2] CISA Alert (AA21-200A) – Chinese APT Actors and Web Shells.
- [3] MITRE ATT&CK;: <https://attack.mitre.org/software/S0011/>

S0012

PoisonIvy

Malware / RAT

01 DESCRIPTION & OVERVIEW

PoisonIvy (also known as Poison Ivy, Darkmoon) is a popular remote access Trojan (RAT) first observed in 2005. It provides attackers with comprehensive remote control capabilities including keylogging, screen capture, audio/webcam surveillance, file management, and remote shell. Despite its age, PoisonIvy has been used in numerous high-profile APT campaigns due to its ease of use and extensive feature set. It is configurable via a GUI builder, lowering the technical barrier for operators.

Threat Actor Association

APT1 (G0006), Elderwood (G0066), Deep Panda, admin@338, Moafee, and numerous other Chinese-nexus APT groups.

Supported Platforms

Windows

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1059.003	Command and Scripting Interpreter: Windows Command Shell
T1056.001	Input Capture: Keylogging
T1113	Screen Capture
T1123	Audio Capture
T1125	Video Capture
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys
T1055	Process Injection
T1071.001	Application Layer Protocol: Web Protocols
T1027	Obfuscated Files or Information
T1012	Query Registry
T1082	System Information Discovery
T1083	File and Directory Discovery
T1041	Exfiltration Over C2 Channel
T1003	OS Credential Dumping

03 OPERATIONAL DETAILS

Execution Method

Delivered primarily via spear-phishing emails with malicious attachments (weaponized Word/PDF). Upon execution, a self-installing dropper places the RAT on disk and activates it. PoisonIvy can also be compiled from a publicly available builder kit, customized with C2 settings, mutex, and install path.

Persistence Techniques

Adds itself to HKCU or HKLM Run registry keys. May also copy itself to the startup folder or create a service entry for persistence across reboots.

Privilege Escalation

PoisonIvy does not include native privilege escalation; however, operators use it to deploy exploits or Mimikatz for escalating privileges on compromised hosts.

Defense Evasion

Injects into legitimate processes (e.g., explorer.exe, svchost.exe) using process hollowing or DLL injection. Uses a custom Camellia cipher for C2 communications encryption. The mutex and install path are configurable per campaign, complicating static detection.

Credential Access

Captures keystrokes to harvest credentials. Operators can deploy credential dumping tools via the RAT's file transfer feature. Captures window titles to identify credential entry contexts.

Discovery Techniques

Enumerates running processes, open windows (captures window titles), system info, installed software, and network configuration.

Lateral Movement

Does not have built-in lateral movement; uses file transfer to deploy tools for network traversal and exploitation of adjacent systems.

Command & Control (C2)

TCP-based C2 over port 3460 (default, configurable). Communications encrypted with Camellia cipher. Supports reverse and bind connect modes. Some variants use custom domains; operators configure C2 at build time.

Exfiltration

Files and captured data (keystrokes, screenshots) are exfiltrated over the C2 TCP channel. Operators can manually transfer files via the RAT's built-in file manager.

Impact Analysis

PoisonIvy has been linked to some of the most impactful espionage operations of the past two decades, including campaigns against defense contractors, government agencies, and media organizations. Its comprehensive surveillance capabilities enable deep intelligence collection.

04 INDICATORS OF COMPROMISE (IOCs)

- Mutex: 'A' or custom name configured at build time
- Registry: HKCU\Software\Microsoft\Windows\CurrentVersion\Run - random name
- Network: TCP port 3460 (default); encrypted Camellia traffic
- Process Injection into explorer.exe, svchost.exe
- File: poisonivy.exe, dropper with .tmp extension in %TEMP%

05 DETECTION & MITIGATION

Detect process injection into system processes. Monitor Run registry key modifications. Use YARA rules for PoisonIvy binary signatures. Network detection: anomalous outbound TCP connections; Camellia-encrypted traffic fingerprinting. Tools: Calamine (free FireEye tool) specifically designed to detect and decode PoisonIvy C2.

06 REFERENCES & SOURCES

- [1] FireEye. (2013). Poison Ivy: Assessing Damage and Extracting Intelligence.
- [2] Symantec. (2014). Trojan.Darkmoon Analysis.
- [3] MITRE ATT&CK;: <https://attack.mitre.org/software/S0012/>



S0013

PlugX

Malware / RAT

01 DESCRIPTION & OVERVIEW

PlugX (also known as SOGU, Kaba, Korplug, RedDelta) is a highly modular remote access Trojan used extensively by multiple Chinese-nexus threat groups since approximately 2008. Its plugin architecture allows operators to extend functionality dynamically, adding modules for keylogging, screen capture, file management, port mapping, and more. PlugX has evolved significantly over the years with new variants emerging regularly, making it one of the most enduring and widely observed RATs in state-sponsored espionage.

Threat Actor Association

APT3 (G0022), APT10 (G0045), APT17 (G0025), APT41 (G0096), Mustang Panda (G0129), Bronze President, Winnti Group, Tropic Trooper.

Supported Platforms

Windows

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1574.001	Hijack Execution Flow: DLL Search Order Hijacking
T1574.002	Hijack Execution Flow: DLL Side-Loading
T1059.003	Command and Scripting Interpreter: Windows Command Shell
T1055	Process Injection
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys
T1543.003	Create or Modify System Process: Windows Service
T1071.001	Application Layer Protocol: Web Protocols (HTTP/HTTPS C2)
T1027	Obfuscated Files or Information
T1056.001	Input Capture: Keylogging
T1113	Screen Capture
T1083	File and Directory Discovery
T1057	Process Discovery
T1082	System Information Discovery
T1041	Exfiltration Over C2 Channel
T1105	Ingress Tool Transfer

03 OPERATIONAL DETAILS

Execution Method

PlugX is delivered via spear-phishing emails with weaponized documents or via exploitation of public-facing applications. A key delivery technique is DLL side-loading: a legitimate, digitally signed executable is bundled with a malicious DLL and an

encrypted payload (DAT file). When the legitimate binary runs, it loads the malicious DLL, which decrypts and executes the payload.

Persistence Techniques

Creates a Windows service for persistence (common in early variants). Also uses registry Run keys and may copy itself to system directories with system/hidden attributes.

Privilege Escalation

Exploits DLL side-loading to run within the context of a privileged application. Some variants attempt UAC bypass techniques to elevate privileges.

Defense Evasion

DLL side-loading using legitimate signed binaries. Encrypted payload stored on disk (DAT file). Configuration and communications are XOR or RC4 encrypted. Can delete itself post-infection, leaving only the service or registry entry. Some variants use timestomping and NTFS alternate data streams.

Credential Access

Keylogging module captures credentials. Operators deploy Mimikatz or other tools via the file transfer feature for credential dumping from LSASS or SAM.

Discovery Techniques

Extensive discovery: process listing, system info, drive enumeration, network configuration, installed software, window titles, and clipboard monitoring.

Lateral Movement

Port mapping module enables tunneling to internal hosts. File transfer enables deployment of additional PlugX instances or other malware on adjacent systems.

Command & Control (C2)

Supports HTTP, HTTPS, TCP, and UDP for C2. Configuration (C2 IP, port, sleep interval) stored in an encrypted DAT file. Some variants support multiple C2 channels and failover. DNS-based C2 also documented in some campaigns.

Exfiltration

Collected data is compressed, encrypted, and exfiltrated over the C2 channel. Operators stage files for collection and manually transfer them via the PlugX file manager.

Impact Analysis

PlugX is one of the most widely deployed APT tools in history, used in campaigns against governments, defense contractors, healthcare, telecom, and NGOs across Asia, Europe, and the US. Its modular design and ongoing development make it a persistent, evolving threat.

04 INDICATORS OF COMPROMISE (IOCs)

- DLL Side-Loading: Legitimate signed EXE + malicious DLL + encrypted .dat file (triad)
- Registry: Service creation or HKLM Run key with random service name
- Network: HTTP/HTTPS beaconing with custom URI patterns; encrypted payload
- File: %SystemRoot%\Installer\, %AppData%\Microsoft\ - hidden/system files
- Mutex: Various campaign-specific mutex names (e.g., 'SMBEvent', 'HQUUserEntry')

05 DETECTION & MITIGATION

Monitor for unsigned DLLs loaded by signed processes. Detect unusual service creation. YARA rules available for PlugX binary patterns. Network: inspect HTTP traffic for PlugX URI patterns and C2 beaconing intervals. Alert on legitimate executables (e.g., VMware, Kaspersky installers) running from unexpected paths.

06 REFERENCES & SOURCES

- [1] Lastline. (2013). PlugX: New Tool For A Not So New Campaign.
 - [2] Recorded Future. (2020). RedDelta PlugX Campaign Targeting Mongolia.
 - [3] MITRE ATT&CK;: <https://attack.mitre.org/software/S0013/>
-

S0014

Regin

Malware / Advanced Persistent Backdoor

01 DESCRIPTION & OVERVIEW

Regin is an exceptionally sophisticated, multi-stage modular backdoor platform believed to be developed by a nation-state actor (widely attributed to the NSA/GCHQ based on the Snowden leaks). First publicly documented by Symantec and Kaspersky in 2014, Regin had been active since at least 2008. It features a complex six-stage encrypted loader architecture, a custom virtual file system (EVFS), and a modular plugin framework, making it one of the most technically advanced malware platforms ever analyzed publicly.

Threat Actor Association

Attributed to Five Eyes intelligence agencies (NSA/GCHQ) based on Snowden document references and technical analysis.

Supported Platforms

Windows (primary); some components target Linux and Cisco IOS routers

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1014	Rootkit
T1027	Obfuscated Files or Information
T1140	Deobfuscate/Decode Files or Information
T1083	File and Directory Discovery
T1056.001	Input Capture: Keylogging
T1113	Screen Capture
T1005	Data from Local System
T1071.001	Application Layer Protocol: Web Protocols
T1090.001	Proxy: Internal Proxy
T1041	Exfiltration Over C2 Channel
T1070	Indicator Removal on Host
T1553	Subvert Trust Controls
T1059	Command and Scripting Interpreter

03 OPERATIONAL DETAILS

Execution Method

Regin uses a six-stage loading chain where each stage decrypts and executes the next. Stage 0 (initial dropper) exploits vulnerabilities or relies on social engineering. Each subsequent stage is encrypted and stored in the registry, NTFS extended attributes, or a custom Encrypted Virtual File System (EVFS). The final stage loads the modular framework.

Persistence Techniques

Uses a kernel-level rootkit (Windows kernel driver) for deep persistence. Components stored in NTFS extended attributes or registry binary blobs, making them invisible to standard OS tools. Hooks boot process to survive reboots.

Privilege Escalation

Operates at kernel level after deploying a signed or exploited driver, granting full SYSTEM privileges. Hooks kernel structures to hide processes, files, and registry entries.

Defense Evasion

Six-stage encrypted loader; each stage individually encrypted. Custom EVFS hides payload files from the Windows file system. Kernel rootkit capabilities: file, process, registry, and network hiding. Timestomping and NTFS extended attribute abuse. Modular design allows tailoring to avoid detection.

Credential Access

Dedicated modules for keylogging and password recovery. Can capture credentials from GSM base station operators, Telco infrastructure, and standard Windows credential stores.

Discovery Techniques

Full system survey via modular plugins: process listing, file system enumeration, network configuration, running services, and installed software.

Lateral Movement

Uses peer-to-peer communication between infected hosts in the same network, allowing C2 traffic to be routed through a single internet-connected node (internal proxy).

Command & Control (C2)

Supports multiple protocols: HTTP, ICMP, and custom TCP protocols. Features a sophisticated P2P layer for intra-network communication, allowing infected machines without internet access to communicate through a relay node. All communications encrypted with RC5 and custom algorithms.

Exfiltration

Data collected by modules is staged in the EVFS and exfiltrated over encrypted C2 channels. Exfiltration is designed to be slow and low-volume to avoid detection.

Impact Analysis

Regin was used for intelligence gathering against governments, telecom operators, research institutions, and international bodies (including European Commission, EU Council). Its GSM targeting capability uniquely allowed interception of mobile network infrastructure, impacting millions of mobile users in target countries.

04 INDICATORS OF COMPROMISE (IOCs)

- NTFS Extended Attributes: Data stored in file extended attributes (invisible via Explorer)
- Driver: Signed or unsigned kernel driver with rootkit capabilities
- Registry: Encrypted binary blobs in obscure registry paths
- Custom EVFS: Virtual file system containers (various filenames)
- Network: ICMP with payload, custom encrypted TCP traffic

05 DETECTION & MITIGATION

Scan NTFS extended attributes using tools like NtfsStreams. Use kernel-mode security tools (e.g., LiveKd, WinPmem) for memory forensics. Deploy threat intelligence feeds with Regin signatures. Monitor for anomalous kernel driver loading. Regin requires advanced forensic analysis; most AV tools were unable to detect it at discovery.

06 REFERENCES & SOURCES

- [1] Symantec Security Response. (2014). Regin: Top-tier espionage tool enables stealthy surveillance.
- [2] Kaspersky Lab. (2014). Regin: Nation-state ownage of GSM networks.

[3] MITRE ATT&CK;: <https://attack.mitre.org/software/S0014/>

S0015

Ixeshe

Malware / RAT

01 DESCRIPTION & OVERVIEW

Ixeshe is a remote access Trojan that has been used since at least 2009, predominantly targeting organizations in East Asia (Japan, Taiwan, and South Korea), with victims including government agencies, telecommunications companies, electronics manufacturers, and aerospace organizations. It provides standard RAT functionality including remote shell access, file transfer, and system reconnaissance. Ixeshe is notable for its long operational life and consistent use in targeted campaigns.

Threat Actor Association

APT12 (IXESHE group / Numbered Panda / DynCalc); Chinese-nexus espionage group.

Supported Platforms

Windows

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1059.003	Command and Scripting Interpreter: Windows Command Shell
T1071.001	Application Layer Protocol: Web Protocols (HTTP C2)
T1082	System Information Discovery
T1016	System Network Configuration Discovery
T1057	Process Discovery
T1083	File and Directory Discovery
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys
T1105	Ingress Tool Transfer
T1041	Exfiltration Over C2 Channel
T1027	Obfuscated Files or Information

03 OPERATIONAL DETAILS

Execution Method

Delivered via spear-phishing emails with malicious PDF or Office document attachments exploiting vulnerabilities (e.g., Adobe Acrobat/Reader CVEs). Upon exploitation, a dropper installs Ixeshe and establishes C2 communication.

Persistence Techniques

Writes to registry Run keys or startup folders to maintain persistence across reboots. May also drop copies to common application directories.

Privilege Escalation

Does not implement native privilege escalation. Relies on initial exploitation providing elevated privileges or user-level access for standard operations.

Defense Evasion

Communications obfuscated and sent over HTTP to blend with normal web traffic. Binary may be packed or obfuscated. Uses custom User-Agent strings in HTTP headers.

Credential Access

Primarily relies on keylogging for credential capture. Secondary tools may be deployed via the file transfer mechanism for credential harvesting.

Discovery Techniques

Performs system profiling: OS version, hostname, IP address, running processes, and drive information. Sends collected profile to C2 for target evaluation.

Lateral Movement

No built-in lateral movement module. Operators deploy additional tools via Ixeshe's file upload capability to move within the target network.

Command & Control (C2)

HTTP-based C2, often using dynamic DNS domains. Beacons at configured intervals with campaign-specific URI patterns. Some variants use multiple C2 servers for redundancy.

Exfiltration

Data exfiltrated over existing HTTP C2 channel. Files are staged locally before transmission to the C2 server.

Impact Analysis

Used in sustained espionage campaigns targeting East Asian governments and technology companies. Enabled long-term intelligence gathering on strategic industries including aerospace and telecommunications.

04 INDICATORS OF COMPROMISE (IOCs)

- Network: HTTP beaconing with campaign-specific URI patterns to dynamic DNS domains
- Registry: HKCU/HKLM Run key modifications with random or system-mimicking names
- File: Malicious PDF/DOC droppers; Ixeshe binary in %TEMP% or %APPDATA%
- Process: cmd.exe spawned from svchost or explorer during initial execution
- C2: Domains using providers like 3322.org, 8866.org (historically)

05 DETECTION & MITIGATION

Monitor HTTP traffic for beaconing patterns (regular interval requests to dynamic DNS). Implement email gateway filtering for malicious PDF/Office documents. Deploy YARA signatures for Ixeshe binary patterns. Registry monitoring for Run key modifications. Patch PDF/Office vulnerabilities promptly to prevent exploitation.

06 REFERENCES & SOURCES

- [1] Moran, N., et al. (2013). Operation Molerats. FireEye.
- [2] Trend Micro. (2012). IXESHE: An APT Campaign.
- [3] MITRE ATT&CK;: <https://attack.mitre.org/software/S0015/>

S0016

Wing

Malware / Downloader

01 DESCRIPTION & OVERVIEW

Wing (also referred to in some contexts as a downloader/dropper component) is a malware tool used in targeted intrusion campaigns. It functions as a first-stage downloader that retrieves and executes additional payloads from attacker-controlled infrastructure. Wing is characterized by its streamlined functionality focused on establishing initial access and delivering secondary stage malware to compromised systems.

Threat Actor Association

APT17 (DeputyDog / Group 27); associated with Chinese-nexus cyber espionage operations.

Supported Platforms

Windows

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1059.003	Command and Scripting Interpreter: Windows Command Shell
T1105	Ingress Tool Transfer
T1071.001	Application Layer Protocol: Web Protocols
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys
T1082	System Information Discovery
T1027	Obfuscated Files or Information
T1041	Exfiltration Over C2 Channel

03 OPERATIONAL DETAILS

Execution Method

Dropped as a first-stage payload following exploitation of vulnerabilities in browsers or document readers, or delivered through spear-phishing. Wing downloads and executes secondary payloads (e.g., PlugX) from C2 infrastructure.

Persistence Techniques

Uses registry Run keys or scheduled tasks to maintain persistence while downloading and launching the final payload.

Privilege Escalation

Relies on the privileges of the initial exploitation vector. No independent privilege escalation capability documented.

Defense Evasion

Encrypted or encoded C2 communications. Binary obfuscation and packing. Uses legitimate-looking filenames and directory paths to avoid attention.

Credential Access

Not a primary function; focused on payload delivery.

Discovery Techniques

Minimal discovery; primarily collects system identifier information to fingerprint the victim machine for C2 registration.

Lateral Movement

Not directly implemented; facilitates lateral movement via secondary payload delivery.

Command & Control (C2)

HTTP-based C2 for payload download and basic command execution. Communicates with attacker infrastructure to retrieve next-stage payloads.

Exfiltration

Minimal; primary role is download/execution rather than data exfiltration.

Impact Analysis

As a delivery vehicle, Wing's impact is defined by the payloads it delivers. In APT17 campaigns, it enabled deployment of PlugX and other espionage tools against government and defense targets.

04 INDICATORS OF COMPROMISE (IOCs)

- Network: HTTP GET requests to C2 for payload download
- Registry: Run key for persistence during download phase
- File: Small executable in %TEMP% or %APPDATA%; payload dropped to disk
- Process: Child process spawning after download completion

05 DETECTION & MITIGATION

Monitor for HTTP downloads from newly registered or suspicious domains. Alert on execution of files downloaded to %TEMP%. Use sandbox detonation for email attachment analysis. Deploy network-level controls blocking known APT17 C2 infrastructure.

06 REFERENCES & SOURCES

- [1] FireEye. (2013). Operation DeputyDog: Zero-Day (CVE-2013-3893) Attack Against Japanese Organizations.
- [2] MITRE ATT&CK;: <https://attack.mitre.org/software/S0016/>

S0017

BISCUIT

Malware / Backdoor

01 DESCRIPTION & OVERVIEW

BISCUIT is a backdoor malware family that has been in use since at least 2007, primarily deployed by APT1 (Comment Crew) in large-scale espionage campaigns. It provides comprehensive remote access functionality to compromised Windows systems, enabling operators to execute commands, transfer files, capture keystrokes, and maintain long-term covert access. BISCUIT was one of the primary tools in the extensive APT1 toolkit documented in Mandiant's landmark 2013 APT1 report.

Threat Actor Association

APT1 (G0006) – Comment Crew / Comment Group; attributed to Unit 61398 of the Chinese People's Liberation Army.

Supported Platforms

Windows

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1059.003	Command and Scripting Interpreter: Windows Command Shell
T1056.001	Input Capture: Keylogging
T1113	Screen Capture
T1071.001	Application Layer Protocol: Web Protocols
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys
T1543.003	Create or Modify System Process: Windows Service
T1082	System Information Discovery
T1083	File and Directory Discovery
T1041	Exfiltration Over C2 Channel
T1027	Obfuscated Files or Information
T1105	Ingress Tool Transfer

03 OPERATIONAL DETAILS

Execution Method

Typically delivered via spear-phishing with malicious attachments or links, exploiting common document reader vulnerabilities. Installs as a Windows service or via run key after initial dropper execution. APT1 conducted high-volume phishing campaigns against targeted organizations to deploy BISCUIT at scale.

Persistence Techniques

Creates a Windows service or adds Run registry key for startup persistence. Service names are designed to mimic legitimate Windows services to avoid scrutiny.

Privilege Escalation

APT1 typically obtained admin access through social engineering or credential reuse; BISCUIT itself does not implement specific privilege escalation exploits.

Defense Evasion

Service names and binary names mimic legitimate Windows components. C2 traffic uses encrypted or encoded HTTP to blend with normal traffic. Operators cycled C2 infrastructure frequently to evade IP/domain blocklists.

Credential Access

Keylogging captures user credentials. APT1 operators used additional credential harvesting tools (Mimikatz, gsecdump) delivered via BISCUIT.

Discovery Techniques

System profiling including OS version, network configuration, running processes, and file system enumeration.

Lateral Movement

Operators used BISCUIT to deploy additional tools for lateral movement. Stolen credentials enabled pass-the-hash and remote service exploitation.

Command & Control (C2)

HTTP-based C2 communication. Commands received via HTTP responses; results transmitted via HTTP POST. Frequently used compromised legitimate websites as C2 relay points.

Exfiltration

Data staged locally then exfiltrated over C2 HTTP channel. APT1 was known for exfiltrating terabytes of intellectual property from victim organizations.

Impact Analysis

BISCUIT was central to APT1's decade-long espionage campaign targeting at least 141 organizations across 20 industries. Enabled massive intellectual property theft estimated at hundreds of gigabytes per victim, covering aerospace, energy, defense, and technology sectors.

04 INDICATORS OF COMPROMISE (IOCs)

- Service: Windows service with name mimicking legitimate services (e.g., 'Windows Audio Manager')
- Registry: HKLM\SYSTEM\CurrentControlSet\Services - malicious service entry
- Network: HTTP C2 beaconing with encoded payloads
- File: DLL or EXE in System32 or Program Files with legitimate-sounding names
- Mandiant APT1 report contains extensive IOC list (hashes, domains, IPs)

05 DETECTION & MITIGATION

Correlate with Mandiant's APT1 indicators (report provides detailed IOC list). Monitor for new service creation with suspicious names or file paths. Alert on HTTP beaconing to unknown/newly-registered domains. Implement application whitelisting to prevent unauthorized service installation. Email filtering and sandboxing for spear-phishing prevention.

06 REFERENCES & SOURCES

- [1] Mandiant. (2013). APT1: Exposing One of China's Cyber Espionage Units.
- [2] MITRE ATT&CK: <https://attack.mitre.org/software/S0017/>

S0018

Sykipot

Malware / RAT / Backdoor

01 DESCRIPTION & OVERVIEW

Sykipot is a malware family used in targeted cyber espionage attacks, particularly against US defense contractors, aerospace companies, and government agencies. It has been observed since approximately 2007 and is notable for its capability to intercept and abuse smart card authentication, enabling attackers to bypass hardware-based authentication systems. Sykipot is delivered via spear-phishing and zero-day exploits, and provides comprehensive remote access and data theft capabilities.

Threat Actor Association

Associated with Chinese-nexus APT actors; closely linked to APT41 and overlapping infrastructure with multiple Chinese espionage groups.

Supported Platforms

Windows

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1059.003	Command and Scripting Interpreter: Windows Command Shell
T1539	Steal Web Session Cookie
T1111	Multi-Factor Authentication Interception (Smart Card)
T1056.001	Input Capture: Keylogging
T1082	System Information Discovery
T1083	File and Directory Discovery
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys
T1071.001	Application Layer Protocol: Web Protocols
T1041	Exfiltration Over C2 Channel
T1027	Obfuscated Files or Information
T1190	Exploit Public-Facing Application

03 OPERATIONAL DETAILS

Execution Method

Delivered via spear-phishing emails exploiting zero-day vulnerabilities in Adobe Reader and Internet Explorer (e.g., CVE-2010-3333, CVE-2011-0611). Upon exploitation, a dropper installs Sykipot and establishes C2 connectivity. Some variants used watering hole attacks targeting defense-sector websites.

Persistence Techniques

Registry Run key modifications and Windows service creation for persistence. Also documented use of scheduled tasks in some variants.

Privilege Escalation

Some variants exploited local privilege escalation vulnerabilities post-initial access. Smart card PIN interception enables elevation by hijacking authenticated sessions.

Defense Evasion

Encrypted C2 communications (custom or XOR). Binary packing and obfuscation. Uses legitimate process injection to hide within trusted processes.

Credential Access

Notable capability: intercepts smart card PINs when users authenticate, allowing attackers to use the physical smart card for unauthorized access. Also performs keylogging for standard credential capture.

Discovery Techniques

System information gathering, network configuration, process enumeration, and targeted search for specific document types (DOC, XLS, PDF, PPT) related to defense and government subjects.

Lateral Movement

Smart card hijacking enables authenticated lateral movement across systems requiring hardware token authentication. Additional tools deployed via C2.

Command & Control (C2)

HTTP/HTTPS-based C2. Some variants used compromised legitimate websites as relay C2 nodes. Domain names registered to mimic legitimate services.

Exfiltration

Targeted document exfiltration via HTTP C2 channel. Prioritizes high-value documents related to defense contracts, government programs, and aerospace technology.

Impact Analysis

Sykipot's smart card attack capability represented a significant advancement in bypassing hardware-based MFA. Its campaigns resulted in theft of classified and sensitive defense-related documents, impacting US national security. Targeted Northrop Grumman, Lockheed Martin, and US government agencies.

04 INDICATORS OF COMPROMISE (IOCs)

- Network: HTTP/HTTPS C2 beaconing with encoded headers
- Registry: Run keys for startup persistence
- Smart Card Hook: API hooking of WinSCard.dll functions
- File: Packed executable in %TEMP% or %APPDATA%; dropped PDF exploits
- C2: Domains mimicking legitimate software vendors

05 DETECTION & MITIGATION

Monitor WinSCard.dll API calls for hooking behavior. Alert on smart card reader access by unexpected processes. Patch Adobe Reader and IE zero-days promptly. Network monitoring for HTTP beaconing to suspicious domains. Implement application allowlisting to prevent unauthorized executables.

06 REFERENCES & SOURCES

- [1] Alienvault/AlienLabs. (2011-2013). Sykipot Analysis Reports.
- [2] Blasco, J. (2012). Sykipot is Back. AlienVault Labs.
- [3] MITRE ATT&CK;: <https://attack.mitre.org/software/S0018/>

S0019

Reaver

Malware / Backdoor

01 DESCRIPTION & OVERVIEW

Reaver is a remote access backdoor used in targeted espionage attacks. It provides standard backdoor capabilities including command execution, file operations, and system reconnaissance. Reaver has been associated with Chinese-nexus threat actors and used in campaigns targeting government and private-sector organizations. It is a relatively lean backdoor designed for persistent access and data collection rather than feature-rich remote control.

Threat Actor Association

Associated with APT groups of Chinese origin; used alongside other Chinese-nexus malware families in overlapping campaigns.

Supported Platforms

Windows

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1059.003	Command and Scripting Interpreter: Windows Command Shell
T1071.001	Application Layer Protocol: Web Protocols
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys
T1082	System Information Discovery
T1083	File and Directory Discovery
T1041	Exfiltration Over C2 Channel
T1027	Obfuscated Files or Information
T1105	Ingress Tool Transfer

03 OPERATIONAL DETAILS

Execution Method

Delivered via spear-phishing or as a secondary payload after initial compromise. Dropper installs Reaver and configures C2 settings before execution.

Persistence Techniques

Registry Run key modifications for startup execution. May also use scheduled task or service creation depending on variant.

Privilege Escalation

No documented native privilege escalation; relies on initial access privileges.

Defense Evasion

Obfuscated binary and encrypted C2 traffic. Uses legitimate-looking file and registry names. May use proxy-aware HTTP communication to blend with enterprise traffic.

Credential Access

Keylogging observed in some variants; primarily relies on operator-deployed credential tools.

Discovery Techniques

Collects system information (OS, hostname, IP, user) for victim profiling. File and directory enumeration for locating valuable data.

Lateral Movement

Facilitates lateral movement via file transfer and deployment of additional tools.

Command & Control (C2)

HTTP-based C2 with encoded or encrypted payloads. Configurable C2 addresses stored in binary configuration.

Exfiltration

Files exfiltrated over HTTP C2 channel; operator-directed targeting of specific file types.

Impact Analysis

Enables sustained covert access to targeted organizations. Used in campaigns targeting government ministries, research institutions, and private sector companies for intelligence collection purposes.

04 INDICATORS OF COMPROMISE (IOCs)

- Registry: HKCU/HKLM Run keys with random or system-mimicking names
- Network: HTTP C2 beaconing with encoded body content
- File: Executable dropped in %APPDATA% or %TEMP% directories
- Process: Unusual child process spawning patterns

05 DETECTION & MITIGATION

Monitor Run registry key modifications. Inspect outbound HTTP for beaconing patterns. Use endpoint detection for anomalous process activity. YARA rules available for Reaver binary variants.

06 REFERENCES & SOURCES

[1] MITRE ATT&CK;: <https://attack.mitre.org/software/S0019/>

[2] Palo Alto Unit 42. [Reaver Backdoor Analysis](#).

S0020

China Chopper

Malware / RAT

01 DESCRIPTION & OVERVIEW

Note: S0020 in MITRE ATT&CK; refers to '3PARA RAT' – a remote access Trojan used by Putter Panda (APT2 / MSUpdater). 3PARA RAT provides standard remote access functionality including command execution, file transfer, and system reconnaissance. It was used in targeted espionage campaigns, particularly against organizations in the US defense industrial base and European targets. The name references its compilation artifact path containing '3para'. It is part of Putter Panda's diverse malware toolkit that also includes HTTPCLIENT and 4H RAT.

Threat Actor Association

Putter Panda (APT2 / G0024); Chinese PLA Unit 61486 (Shanghai).

Supported Platforms

Windows

02 ATT&CK TECHNIQUES USED

ATT&CK; ID	Technique Name
T1059.003	Command and Scripting Interpreter: Windows Command Shell
T1071.001	Application Layer Protocol: Web Protocols (HTTP C2)
T1082	System Information Discovery
T1057	Process Discovery
T1083	File and Directory Discovery
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys
T1041	Exfiltration Over C2 Channel
T1027	Obfuscated Files or Information
T1105	Ingress Tool Transfer
T1056.001	Input Capture: Keylogging

03 OPERATIONAL DETAILS

Execution Method

Delivered via spear-phishing emails targeting US defense contractors and satellite/aerospace companies. Exploits vulnerabilities in common document readers and office software. Upon exploitation, 3PARA RAT is installed and establishes C2 communication.

Persistence Techniques

Creates Windows registry Run key entries. May also create Windows services for persistence depending on available privileges.

Privilege Escalation

Relies on initial exploitation for elevated access. Operators deploy additional privilege escalation tools if needed.

Defense Evasion

Encrypted HTTP C2 traffic with custom encoding. Binary packed to evade signature-based AV. Path manipulation using system directory names.

Credential Access

Keylogging for credential capture. Operators may deploy additional credential harvesting tools via file transfer.

Discovery Techniques

Comprehensive system profiling: hostname, OS version, installed software, running processes, network configuration, and user account information.

Lateral Movement

No built-in lateral movement; operators use file transfer to deploy additional tools for network traversal.

Command & Control (C2)

HTTP-based C2 with custom-encoded headers and body content. Configuration includes primary and backup C2 addresses. Beacon interval and C2 details configurable at compile time.

Exfiltration

Data collected on disk then exfiltrated via HTTP C2 channel. Targeted at satellite technology, defense contracts, and technology specifications.

Impact Analysis

3PARA RAT enabled Putter Panda's espionage campaigns against US and European defense industrial base targets, compromising satellite technology companies and government contractors. Theft of sensitive technical data with implications for national security and technology competitiveness.

04 INDICATORS OF COMPROMISE (IOCs)

- PDB path artifact: contains '3para' string in debug symbols
- Registry: HKCU/HKLM Run key – often mimicking legitimate update services
- Network: HTTP C2 with custom encoded headers; regular beaconing intervals
- File: Packed executable; drops to %APPDATA% or system directories
- Mutex: Campaign-specific mutex name to prevent double-infection

05 DETECTION & MITIGATION

Scan binaries for '3para' PDB artifact string. Monitor Run registry modifications and service creation. HTTP traffic analysis for beaconing patterns and custom encoding. CrowdStrike's 2014 Putter Panda report provides detailed IOCs. Implement email security controls against spear-phishing delivery.

06 REFERENCES & SOURCES

- [1] CrowdStrike Intelligence. (2014). Putter Panda. CrowdStrike Global Intelligence Report.
- [2] MITRE ATT&CK;: <https://attack.mitre.org/software/S0020/>